Solución de seguridad SDN para una red de campus académico

Exposición parcial — arquitectura, infraestructura y diseño de R1 · R2 · R4

> La plataforma **decide**; el controlador **traduce**; los switches **ejecutan**.

Alcance de este documento

R1 · implementado | R2 · implementado | R4 · implementado | R3 · solo diseño | R5 · solo diseño

General	Arquitectura + infraestructura	30 pts
Doc/Pres.	Documentación y presentación	10 pts
R1	Acceso según rol	10 pts
R2	Recursos privilegiados	10 pts
R4	DDoS brute-force interno	20 pts
R3	Ataques encubiertos	20 pts
R5	Seguridad perimetral	20 pts

Peso en la rúbrica. R3 y R5 se cubren a nivel de arquitectura (reutilizan la cadena de R4).

Rodrigo Rojas Soplin
Líder

Piero Oropeza León
Arquitecto

Camila Altamirano Ramírez
PM / QA

Vincenzo Tavella Rivero
DevOps / SRE

Grupo 3 · Horario H0892 · Coach: Germán Espinoza · Prof. Christian Quispe · Octubre 2026 · Base: commit 9626b2b



Fig. 1 — La solución en una figura: tres planos con responsabilidades que no se cruzan y un bucle que no se da por cerrado hasta que el tráfico real lo confirma.

Arquitectura de la solución: capas × planos

Separación estricta de planos: la decisión es **una sola, central y auditable**; la ejecución es **distribuida**, en el switch de ingreso de cada flujo.

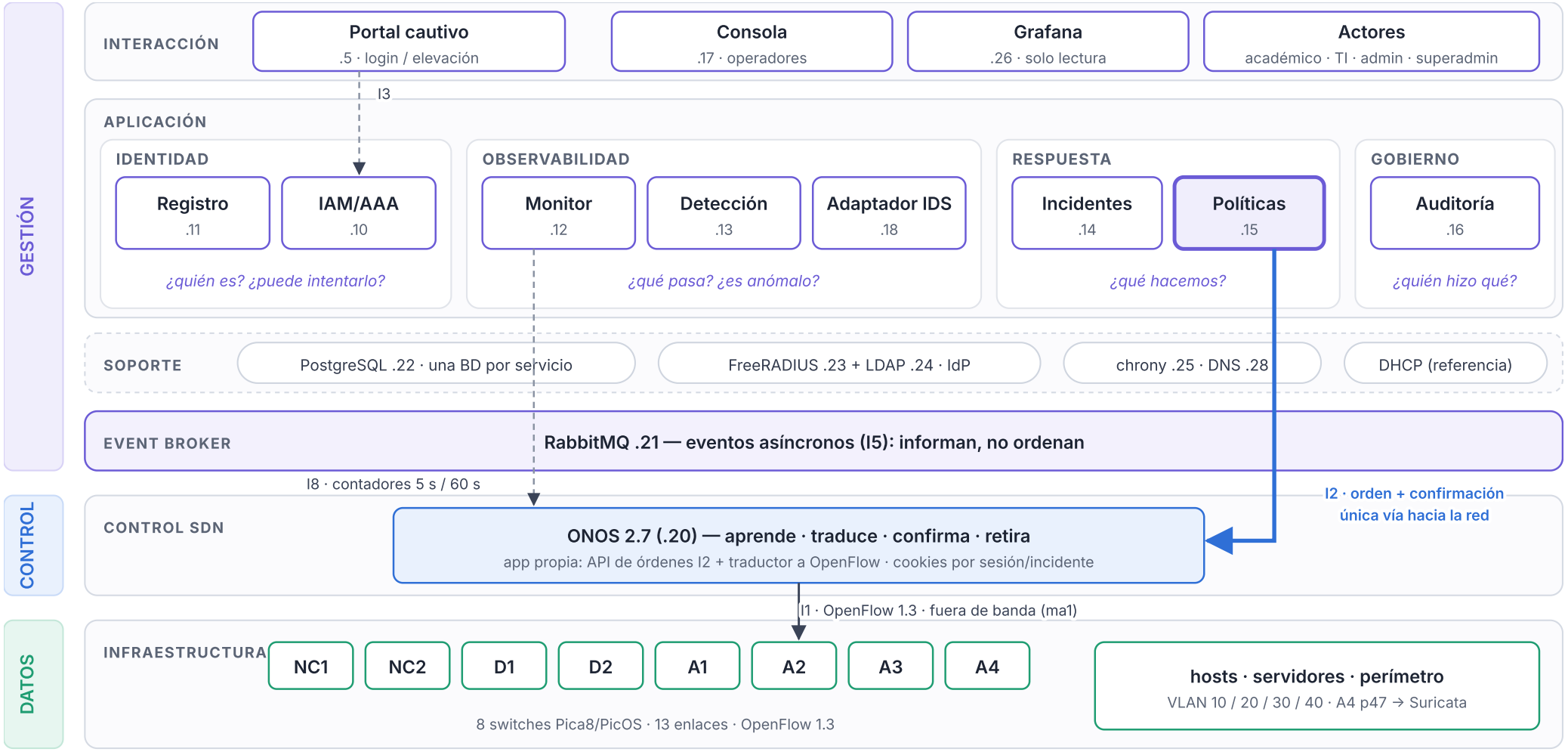


Fig. 2 — Arquitectura en capas superpuesta a los tres planos SDN. Línea azul sólida = la única orden que llega a la red (Políticas → ONOS); líneas grises = información.

Cuatro estilos, cuatro dimensiones

Capas (estructura) · **Eventos/Broker** (reacción) · **Cliente-servidor** (login, consola, órdenes) · **Microservicios** (descomposición).

Tres patrones, cada uno en su sitio

Broker entre servicios · **Pipe-and-Filter** solo dentro de Detección · **Repository**: una base por servicio, sin JOIN entre bases.

Evento informa, comando ejecuta

Lo que exige confirmación (perfil, mitigación) viaja síncrono por I2; su eco se publica al bus para Auditoría y Consola.

Módulos, interacción y extensibilidad

Portal .5
¿Por dónde se acredita?
Única superficie que BASE alcanza (regla 150)

IAM/AAA .10
¿Quién es?
IdP vía RADIUS/LDAP · operadores con TOTP

Registro .11
¿Puede intentar un rol privilegiado?
La MAC es atributo, no credencial

Monitor .12
¿Qué está pasando?
Contadores + línea base EWMA; verifica mitigaciones

Detección .13
¿Es anómalo?
Pipe-and-Filter: captura → features → clasificación

Incidentes .14
¿Qué incidente y en qué estado?
ABIERTO → EN_MITIGACIÓN → MITIGADO → CERRADO

Políticas .15
¿Qué puede hacer, aquí y ahora?
ABAC + escalera · único que emite órdenes I2

Auditoría .16
¿Quién hizo qué, cuándo y por qué?
JSONL append-only con cadena SHA-256

Consola .17
¿Cómo opera el humano?
Alertas, aprobación de elevaciones, políticas

Adaptador IDS .18
¿Qué vio el perímetro?
Traduce eve.json de Suricata a AnomalyDetected

Fig. 3 — Diez servicios, una pregunta cada uno. Si un elemento no responde una pregunta, sobra. Separación lógica innegociable; en despliegue se co-localizan por afinidad (pág. 5).

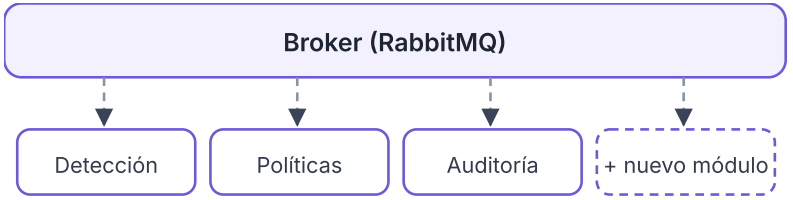
SÍNCRONO — espera respuesta

- Portal → IAM (I3) · login
- IAM → IdP (I4) · RADIUS / LDAP
- Políticas → ONOS (I2) · orden + confirmación
- Monitor → ONOS (I8) · contadores
- Consola → servicios (I7)

ASÍNCRONO — bus de eventos (I5)

- DeviceConnected · SessionOpened
- AnomalyDetected · IncidentOpened
- MitigationRequired · MitigationApplied
- MitigationVerified · MitigationExpired
- ElevationGranted · MAC_Moved

Fig. 4 — Frontera síncrono / asíncrono, deliberada.



Un módulo nuevo se suscribe al bus: nadie más cambia.

Fig. 5 — Extensibilidad sin romper la solución.

¿Por qué ONOS? (elección del controlador)

	ONOS	Ryu	Floodlight
API northbound REST	nativa	vía app	nativa
OF 1.3: meters · groups	sí	sí	parcial
Clúster HA nativo	Raft	no	no
Lenguaje / equipo	Java	Python	Java

¿Por qué un broker?
Un ataque es un suceso que muchos deben conocer sin que el emisor se acople a nadie. Colas durables, DLQ e idempotencia por `evento_id`.

¿Por qué no fusionar servicios?
Cada pregunta tiene dueño, contrato y persistencia propia: la cadena de decisión queda auditable y cada pieza escala por separado.

Infraestructura física y lógica del prototipo

Jerarquía de tres niveles (núcleo · distribución · acceso): **ningún fallo único de enlace o switch** separa a un acceso del resto de la red.

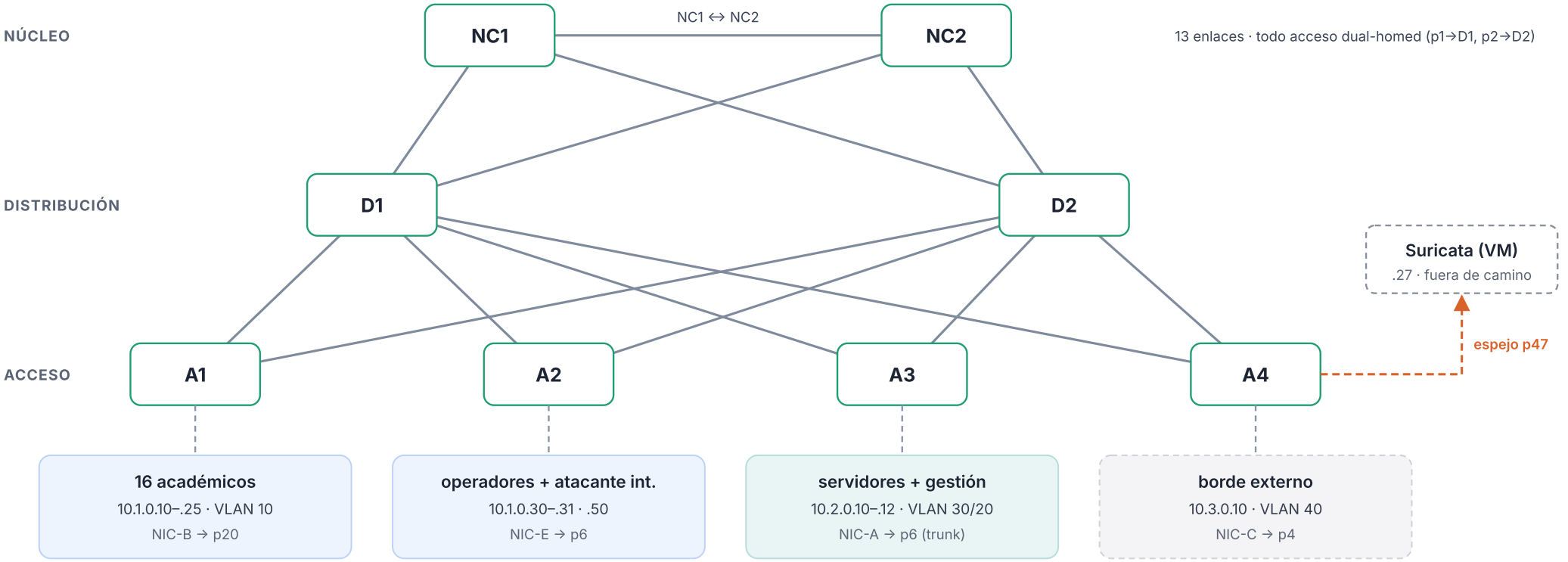


Fig. 6 — Topología física del prototipo: 8 switches Pica8/PicOS en tres niveles. Cada población entra por una NIC distinta del servidor para que la topología coincida con la política.

VLAN 10 · USUARIOS	VLAN 20 · GESTIÓN	VLAN 30 · SERVIDORES	VLAN 40 · EXTERNA
10.1.0.0/24	10.0.0.0/24	10.2.0.0/24	10.3.0.0/24
académicos · operadores · atacante interno	plataforma · ONOS · broker · BD · IdP	general .10 · privilegiado .11 · crítico .12	origen de los escenarios R5

La VLAN no concede permisos: agrupa y direcciona; el permiso vive en las reglas del pipeline. **VLAN 20 ≠ canal OOB:** la VLAN 20 es un segmento del plano de datos; `ma1` es el canal físico de control.

Despliegue, redundancia y tolerancia a fallos

Prototipo: **una** instancia ONOS y redundancia del plano de datos **desplegada**. Referencia: clúster ONOS de 3 nodos con switches apuntando a varios controladores.

Servidor de laboratorio · KVM/libvirt · 32 GB (variante 16 GB)

IDENTIDAD
- Portal
- IAM
- Registro
- FreeRADIUS+LDAP

OBSERVABILIDAD
- Monitor
- Detección
- Adaptador
- Grafana

RESPUESTA
- Incidentes
- Políticas

GOBIERNO
- Auditoría
- Consola

INFRAESTRUCTURA: ONOS · RabbitMQ · PostgreSQL · chrony · DNS

24 VMS (LO QUE LA RED VE COMO EQUIPO REAL)

16 académicos · 2 operadores · 2 atacantes · 3 servidores · 1 sensor

Fig. 7 — Despliegue por afinidad: **mismo host no es mismo servicio**. Regla: lo que la red debe ver como equipo (MAC/IP/puerto propios) es VM; un proceso sin identidad de red es contenedor.

Cae enlace A1–D1	PORT_STATUS → camino por D2 (fast-failover o recálculo)	tiempo de conmutación
Cae NC1	el núcleo sigue completo por NC2	tiempo de recuperación
Cae ONOS	las reglas instaladas siguen; las nuevas decisiones esperan · referencia: clúster de 3	re-registro / reconciliación
Cae RabbitMQ	colas durables + DLQ; huecos declarados	tiempo de recuperación
Cae Detección	sin detecciones nuevas; mitigaciones vigentes siguen	duración de degradación
Cae Suricata	R5 pierde detección; la red NO se corta (fuera de camino)	tiempo de recuperación

Fig. 8 — Matriz de fallos. Verde: redundancia desplegada y medible en vivo. Ámbar: degradación explícita, nunca silenciosa.

PROTOTIPO — SE DESPLIEGA Y SE MIDE



REFERENCIA — SE DISEÑA

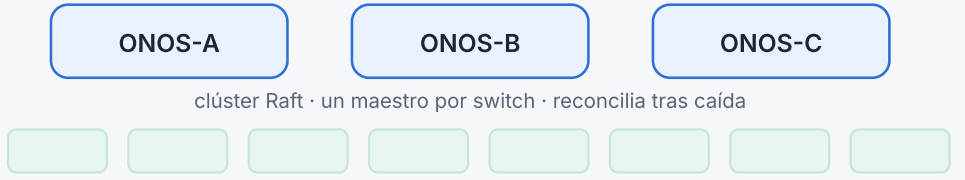


Fig. 9 — Redundancia del plano de control: las reglas ya instaladas sobreviven a la caída del controlador (los switches siguen reenviando); el clúster cubre las decisiones nuevas.

Integración campus
IdP institucional vía RADIUS/LDAP · DNS .28 · DHCP en la regla BASE (hosts del prototipo con IP fija por reproducibilidad).

Crecimiento
Nuevo acceso = dual-homed a D1/D2 · nueva VLAN = nuevas reglas, no nuevo diseño · usuarios → sesiones y TCAM (pág. 7).

Servidores protegidos
Aislamiento físico (A3, VLAN 30) y lógico (DROP desde BASE a gestión, prioridad 100). Control solo por OOB.

Monitoreo
Telemetría por contadores OpenFlow (puerto/flujo) vía ONOS + paneles Grafana; reloj común chrony para correlacionar.

R1 — Controlar el acceso a la red según el rol

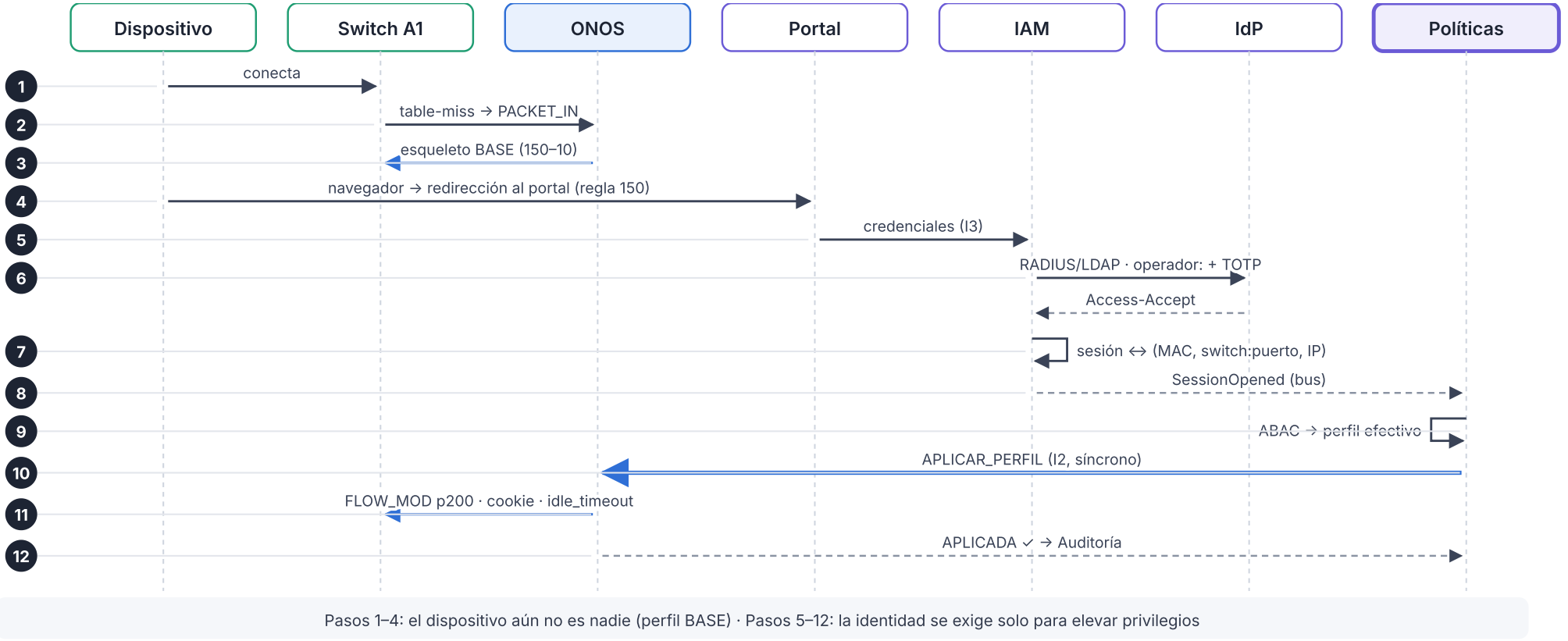


Fig. 10 — Flujo de conexión y login (CU-01) en orden exacto. Monitor y Detección no participan aquí. El Portal es solo la puerta: no valida nada.

OPERADOR — 15 min idle · 8 h
registro + credencial + TOTP → según rol TI / Admin / Superadmin

ELEVADO — TTL 1 h
solicitud + aprobación admin → laboratorio / investigación

ACADÉMICO — 30 min idle · 12 h
login contra el IdP → servicios académicos + Internet

BASE — permanente
presencia física → DHCP · DNS · ARP · portal

Fig. 11 — Escalera de perfiles: cada peldaño exige más identidad y dura menos.

Permiso efectivo = Rol ∧ Recurso ∧ Acción ∧ Contexto ∧ Vigencia ∧ Estado de seguridad

Roles (nivel 0–3)
Usuario académico (alumno + docente) · Especialista TI · Administrador de Red · Superadministrador. Atacantes no tienen rol: son comportamiento observado.

Cómo se supervisa
Auditoría registra autenticación, autorización y elevación; `FLOW_REMOVED` informa cada expiración; retiro siempre por cookie.

Multiplataforma
Basado en navegador (portal cautivo): cualquier SO. 802.1X queda para puertos sensibles en la referencia.

Métricas a medir
Latencia login→regla, tasa éxito/fallo y **logins/s sostenibles** (ráfaga de altas concurrentes en CU-01).

R2 — Restringir los recursos privilegiados a usuarios autorizados

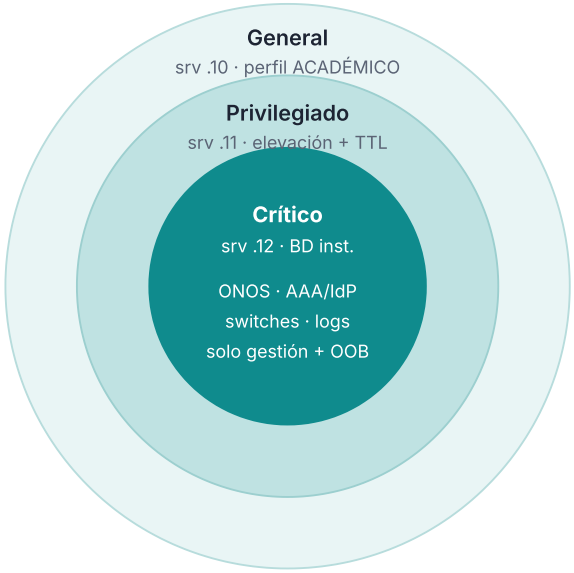


Fig. 12 — Recursos clasificados (R2.2). Cuanto más al centro, más controles; la infraestructura de la propia solución es crítica.

1000	Mitigación	meter / DROP · cookie incidente · TTL
200	Sesión / elevación	allow al perfil · cookie sesión
150	Portal	pre-login → 10.0.0.5
120	Par MAC/IP aprendido	→ caminos
110	Anti-spoofing	IP ok ∧ MAC ≠ → DROP
100	Destino gestión	DROP permanente
20	Caminos	ipv4_dst → puerto (todos los tramos)
10	DHCP / DNS	UDP 67/68, 53
—	Table-miss	PACKET_IN → aprender / portal

más autoridad sobre el paquete

ESQUELETO BASE (150–10)

Fig. 13 — Pipeline lógico en el switch de ingreso: la prioridad es jerarquía de autoridad. La sesión **vence** al esqueleto pero no lo **reemplaza**: el DROP a gestión es permanente.

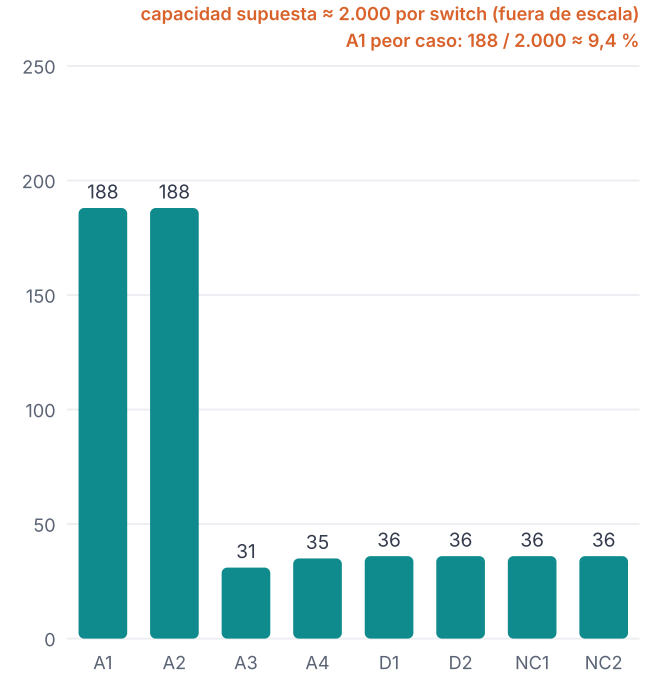


Fig. 14 — Entradas estimadas por switch, peor caso concurrente.

N(A1) = 16×6 base + 16×4 sesión + 8 caminos + 20 mitigación = **188**

Mecanismo

RBAC con atributos (ABAC): Políticas decide, ONOS traduce, el switch de ingreso bloquea **antes** de que el flujo llegue al recurso.

Carga del controlador

Solo el primer paquete sube (PACKET_IN); lo demás se resuelve en hardware. Las reglas se instalan por perfil, no por paquete.

Escenarios de TCAM

Nominal ≈ 363 entradas en los 8 switches (envolvente 350–450); peor caso concurrente ≈ 586.

A medir (V1)

Capacidad real del Pica8: instalar por lotes hasta `OFPFMFC_TABLE_FULL` . El 2.000 es supuesto hasta medirlo.

R4 — Detectar y mitigar DDoS brute-force en la intranet



Fig. 15 — Bucle cerrado de R4. ONOS confirma que **instaló**; solo el Monitor confirma que el tráfico **bajó**. La mitigación se aplica en el switch donde entra el ataque, no junto al destino.

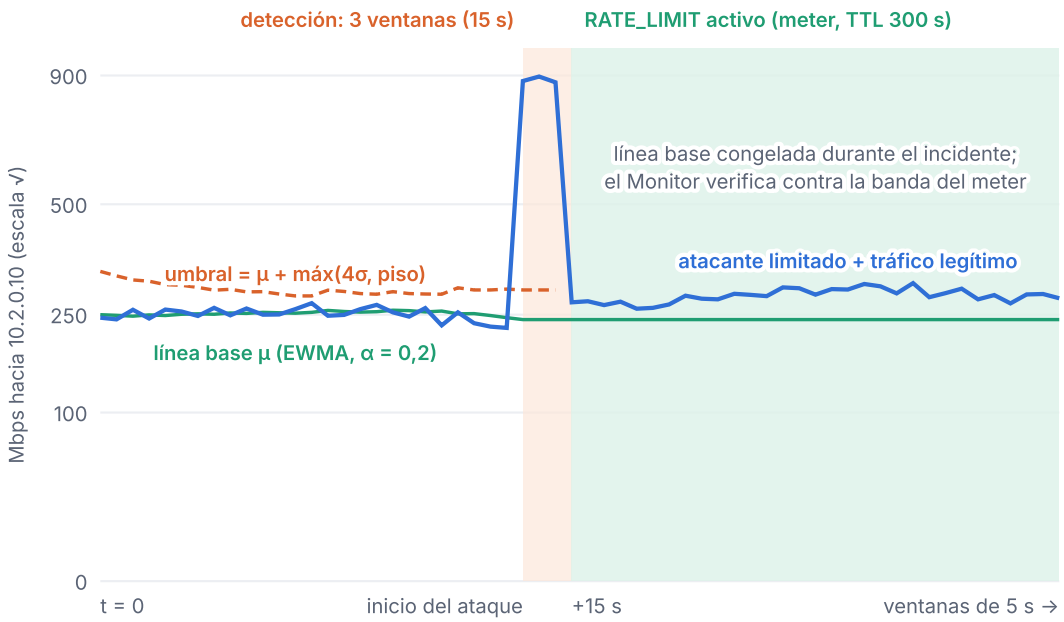


Fig. 16 — Detección adaptativa (ilustrativo): el umbral sigue al tráfico normal, pero un piso de 200 pps / 2 Mbps evita disparos triviales; histéresis 4σ entrada / 2σ salida; 30 min de calentamiento.

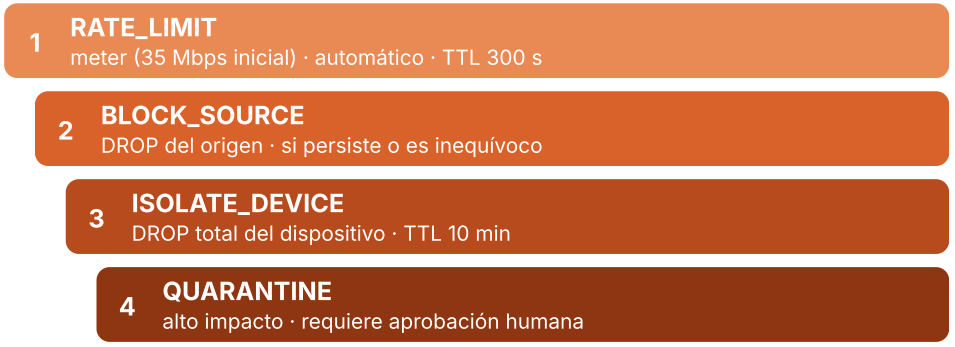


Fig. 17 — Escalera de mitigación: proporcional y reversible.

Patrón lento: T_mitigate ≈ 15,2 s · vía rápida (N = 1): ≈ 5,2 s

T_detect = 3 ventanas × 5 s = 15 s — +185 ms

evento 15 · política 25 · I2 80 · OpenFlow 45 · ASIC 20 (ms) — presupuesto de diseño

Casi todo el tiempo es decidir con confianza, no ejecutar.

Clase	Indicador	Regla inicial
Flood / DDoS	pps, bps a destino	≥ 4σ y piso, 3 ventanas
Brute-force	solicitudes/s por origen	≥ 20/s sostenidas
Distribuido	fuentes distintas	≥ 10 en 60 s → mitiga en cada ingreso

R3 y R5 a nivel de arquitectura, y trazabilidad completa

R3 · diseño **Ataques encubiertos en la intranet**

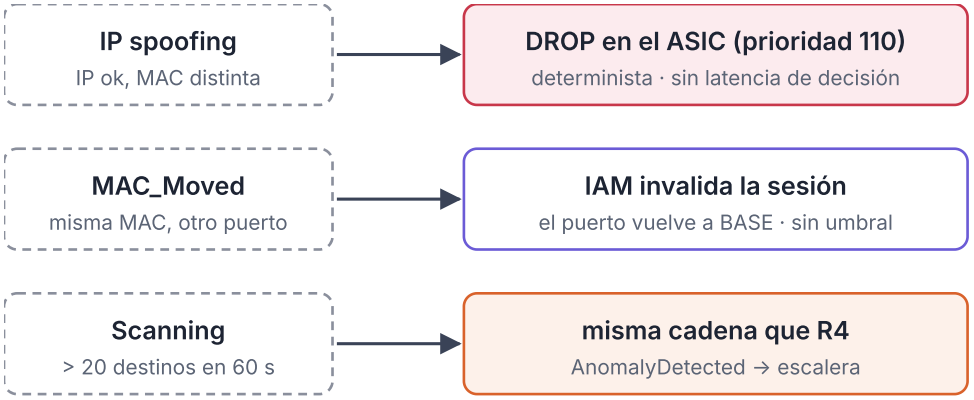


Fig. 18 — Lo determinista se resuelve en el switch o por incoherencia; lo estadístico reutiliza la cadena de R4. La sesión ata identidad a ubicación: moverse la rompe.

R5 · diseño **Seguridad perimetral**

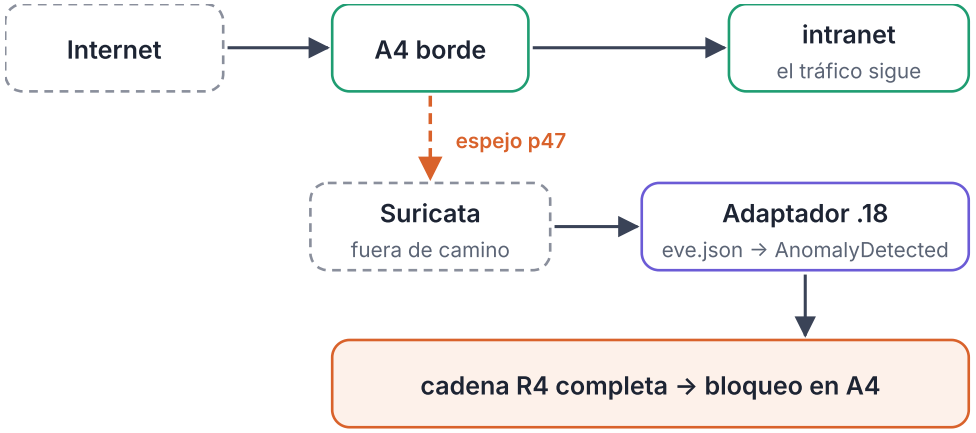


Fig. 19 — IDS fuera de camino: si cae, se degrada R5 pero no se corta el campus. Desde `AnomalyDetected` el sistema no distingue origen interno o externo. Pendiente: listas negras dinámicas y filtrado DNS.

Trazabilidad: requisito → módulo → mecanismo → métrica → prueba

	MÓDULOS	MECANISMO	MÉTRICA	PRUEBA
R1	IAM · Registro · Políticas · ONOS	portal + RADIUS/LDAP · TOTP · FLOW_MOD p200 + cookie + idle_timeout	latencia login→regla · éxito/fallo · logins/s	CU-01 · CU-02 · elevación con TTL
R2	Políticas · switch de ingreso · Auditoría	ABAC · DROP a gestión (p100) · anti-spoofing (p110)	permitidas/denegadas · entradas TCAM	CU-03 · CU-04 · llenado de tabla
R4	Monitor · Detección · Incidentes · Políticas · ONOS	EWMA + piso + N = 3 · METER / DROP p1000 · verificación	T_detect · T_mitigate · tráfico residual · FP · tráfico legítimo	CU-07 con tráfico legítimo en paralelo
R3	Monitor · Detección · IAM	p110 · MAC_Moved · scanning	cobertura · T_detect	CU-05 · CU-06
R5	Suricata · Adaptador · Políticas	espejo A4 → IDS → bloqueo SDN en A4	tiempo de alerta y de bloqueo	CU-08

El laboratorio debe cerrar: V1 capacidad TCAM real y multi-tabla V2 meters nativos V3 grupos fast-failover M1 T_detect · T_mitigate · residual · FP M2 carga ONOS a 5/30/60 s

Todas las cifras de este documento son de diseño, no resultados experimentales.